

JWT authentication bypass via flawed signature verification

Topic: JWT | Difficulty: Apprentice

Description

The JWT library accepts the 'none' algorithm which specifies that no signature is required. By changing the algorithm header to 'none' and stripping the signature an attacker can forge tokens with arbitrary claims and gain unauthorized access. This is a classic critical JWT implementation flaw.

Steps to Exploit

1. Log in and extract the JWT from the session cookie.
2. Decode the three base64url-encoded parts of the JWT.
3. In the header JSON change the 'alg' field from 'RS256' to 'none'.
4. In the payload JSON change the 'sub' field to 'administrator'.
5. Re-encode header and payload as base64url; set signature to empty string.
6. Construct the forged token as: <header>.<payload>. (trailing dot, no signature).
7. Set this as the session cookie and access /admin.

Proof of Concept

Original Header:

```
{"alg": "RS256", "typ": "JWT"}
```

Forged Header:

```
{"alg": "none", "typ": "JWT"}
```

Forged Token Format:

```
<base64url(header)>.<base64url(payload)>.
```

Result:

Server accepts unsigned token and grants admin access.

Impact

- Signature requirement completely bypassed.
- Arbitrary JWT claims accepted as valid by the server.
- Full privilege escalation to any user identity including administrator.
- Entire authentication mechanism undermined.

Mitigation / Remediation

1. Explicitly reject tokens with alg='none' on the server side.
2. Use a strict allowlist of permitted algorithms (e.g., only RS256 or ES256).
3. Use a battle-tested JWT library that disables the 'none' algorithm by default.
4. Regularly audit JWT configuration and library versions for known vulnerabilities.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

- Attack Vector: Network - cookie manipulation via browser or proxy.
- Attack Complexity: Low - simple header field modification.
- Privileges Required: None - works from any session token.
- User Interaction: None.
- Confidentiality / Integrity: High - full administrator access.
- Availability: None.